attacks involve lost devices with inadequate device security or a virus infection that can expose the key store. These issues can be mitigated with good device hygiene. If your organization isn't already using them, that should be the first thing you address before worrying about authorization or zero-trust, because it's the quickest way to make your services easier to use and more secure at the same time.

3.8 Connecting authentication and authorization

Authentication and authorization are deeply connected and often discussed in tandem. But they serve very different purposes. As we've discussed, the identity relationship formed during enrollment is validated for each interaction during authentication. Due to the proximity problem, authentication must continually verify the participants in any digital interaction.

As we discovered in the preceding section, selecting and configuring an authentication system has a big impact on its strength and usability. When authentication is weak, authorization decisions are based on a shaky foundation where attackers are potentially impersonating others. An attacker might pose as Alice, gaining access to anything she has permissions for if the authentication process is too weak to confirm she's really making the request.

3.8.1 Identity as context

When Alice authenticates, the system not only validates the identifier but also gains a relationship context—all the information recorded about Alice since her enrollment. This can include contextual elements such as:

- Attributes (for example, department, clearance level, subscription tier)
- Roles (for example, admin, contributor, viewer)
- Group memberships
- Device posture and location
- Recent behavior or signals of compromise
- Preferences or other information gleaned from Alice's actions.